

Seguridad de la Información – Curso 2025-26

PRÁCTICA 5 – CORREO ELECTRÓNICO SEGURO OPENPGP

5.- Envío y recepción de mensajes OpenPGP firmados y cifrados, empleando OpenPGP sobre Thunderbird, y su decodificación manual con la herramienta GnuPG.

En esta quinta práctica, se trata de **configurar un agente de correo electrónico** para una cuenta de correo privada del usuario e **incorporar la funcionalidad de empleo de correo seguro OpenPGP**, creando una pareja de claves OpenPGP para el usuario, de forma que intercambie un correo electrónico firmado y cifrado entre dos compañeros. Seguidamente, al igual que en el apartado anterior, se exportará ese mensaje cifrado y firmado con OpenPGP junto con las claves necesarias y se decodificará manualmente con la utilidad GnuPG (comandos gpg).

Como agente de correo electrónico **recomendamos encarecidamente el Mozilla Thunderbird** y la **cuenta de correo empleada por el estudiante NO debe ser la institucional de la ULPGC**, pudiendo utilizarse cualquier cuenta de correo electrónico de servicios gratuitos como Hotmail, Gmail, etc.

NOTA: Cuando hablamos de un **compañero**, puede ser un compañero real o bien nosotros mismos podemos actuar con **dos cuentas de correo diferentes** y hacer de nosotros mismos y del compañero, **PERO** en este caso, han de utilizarse **DOS** instancias diferentes del programa Thunderbird (por ejemplo, una en la máquina virtual y otra en el anfitrión). De no hacerse así, con dos instancias diferentes de Thunderbird, la práctica será rechazada.

5.1. Configuración de nuestra cuenta en Thunderbird para el empleo de OpenPGP

Es parte del trabajo a realizar la búsqueda activa de información al respecto. En cualquier caso, se pueden distinguir algunas etapas previas a la realización del envío del correo seguro:

- Antes de comenzar esta parte el estudiante podría eliminar de la configuración del Thunderbird toda la configuración realizada en el apartado anterior, eliminando el certificado S/MIME de la parte 2 ... **pero no lo aconsejamos**, ya, el programa **Thunderbird permite que coexistan configuraciones de S/MIME y OpenPGP**, con el empleo habitual de mensajes sin cifrar ni firmar por ninguno de los dos sistemas. Es decir, si nuestro interlocutor no está almacenado en ninguna de las dos bases de datos de direcciones asociadas a clave pública SSL u OpenPGP, el comportamiento del Thunderbird será idéntico al convencional, y siempre se podrá configurar Thunderbird para que en su comportamiento por defecto, realice envíos cifrados, firmados (mediante OpenPGP y OpenSSL) o sin seguridad a direcciones asociadas a una clave pública o certificado X.509.
- A continuación, acceder en el menú superior a la opción **Herramientas / Configuración de cuenta** que abre una nueva pestaña, y en el menú de la izquierda seleccionar, abriendo la configuración de la cuenta escogida, la opción **"Generate OpenPGP Key"**. En la pantalla siguiente, indicar que la clave no expira y el tipo de clave y tamaño recomendado. Finalizada la generación de las claves, se regresa a la pantalla anterior donde vemos que ya están activadas las claves OpenPGP para la cuenta seleccionada. Es importante asegurarnos de

que **NO** hemos activado el cifrado por defecto ni el envío de firmas de manera predeterminada,

- A partir de ese momento, ya podríamos enviar mensajes firmados (todavía sin cifrar) con OpenPGP haciendo uso de la opción "Seguridad" de la pantalla de envío de mensajes y activando la casilla correspondiente, pero no tendría mucho sentido hacerlo a quién no tenga habilitada esta funcionalidad de correo seguro OpenPGP.
- Ahora, aconsejamos en esa misma pestaña, pulsar de nuevo el botón de "OpenPGP Key Manager" y seleccionando la clave recién creada, usar la opción de "**File/Backup secret keys to file**" para hacer una copia de la clave privada con contraseña, para conservarla en lugar seguro y acto seguido, la opción de "**File/Export Public Key to file**". Este último fichero puede ser enviado a cualquier compañero con el que queramos hacer una prueba de envío de mensaje firmado y cifrado, ya que sólo se puede cifrar un mensaje a una dirección de correo de la que tengamos su clave pública. Si enviamos el fichero de clave pública a un compañero, él podrá desde este mismo programa usar la opción inversa de "**File/Import Public Keys from File**" y validar nuestra clave pública. Es decir, una vez se hayan intercambiado las claves públicas entre dos o más compañeros, también se podrán intercambiar mensajes cifrados.
- Como **alternativa más cómoda**, se pueden **intercambiar mensajes sólo firmados** y los receptores de cada mensaje pueden **incorporar** la clave pública del remitente al almacén de claves de la herramienta "OpenPGP Key Manager" antes indicada, a continuación **darle validez a la clave**, y a partir de ese momento, se pueden enviar mensajes tanto firmados como cifrados.

Por tanto, repetimos que es muy **conveniente**, siempre que se pueda, **practicar entre compañeros** el envío de mensajes firmados y cifrados. Si A le envía a B un mensaje firmado y su clave pública, B dispondrá de la clave pública de A y podrá cifrar mensajes hacia él, sin necesidad de importar manualmente la clave. Por tanto, esta parte del trabajo finaliza cuando podemos ver (y capturar) en la pantalla de Thunderbird el mensaje cifrado y firmado por el compañero.

Es extremadamente importante que, una vez recibido el mensaje del compañero firmado y cifrado, procedamos a **importar** su clave pública y a **asignarle la máxima confianza a su clave**. Hasta que estos dos pasos no estén realizados, la pantalla que muestra el mensaje firmado y cifrado del compañero no tendrá un **"sello verde"** en la etiqueta que indica que está firmado con una clave de confianza. Este sello estará marcado en **azul** cuando aún no se ha importado la clave y en **amarillo** hasta que no se confiera máxima confianza a la clave del compañero. **No se aceptará una entrega** que no indique explícitamente el sello verde y capturas de las dos operaciones necesarias para que este aparezca.

5.2. Decodificación manual del mensaje cifrado y firmado con OpenPGP utilizando la utilidad Gnupg

5.2.1. Prerrequisitos

Para realizar este apartado es necesario tener instalada la utilidad "gnupg", es un paquete muy común en distribuciones de Linux y en muchas está instalado por defecto.

También puede ser necesaria la utilidad "ripmime" de utilidades MIME, ya citada en la práctica 1.

5.2.2 Secuencia de operaciones

Una vez intercambiado el mensaje cifrado y firmado con claves OpenPGP entre compañeros, hacemos una breve descripción de los pasos necesarios, suponiendo que no se tiene configurado el uso de GnuPG en nuestro equipo:

Descargar del OpenPGP Key Manager de Thunderbird una copia de nuestra clave privada, protegida por contraseña (a un fichero claveprivada.asc).

Descargar también la clave pública del compañero que envió el mensaje (a un fichero clave.asc).

Exportar (guardar cómo...) el mensaje cifrado y firmado como “mensaje.eml”.

Ahora importamos nuestra clave privada en gnuPG:

```
# gpg --import claveprivada.asc      (debe solicitar contraseña, en algunos sistemas se requiere la instalación previa de gpg-agent)
```

Se importa la clave pública del remitente del mensaje en gnuPG:

```
# gpg --import clave.asc      (en ocasiones se queja de caracteres inconsistentes, en ese caso habría que hacer #gpg --dearmor clave.asc , lo que crearía un fichero clave.asc.gpg y se repite el comando con este fichero, # gpg --import clave.asc.gpg)
```

Y finalmente se descifra y verifica la firma del mensaje:

```
# gpg --decrypt mensaje.eml      (se puede leer en pantalla)
```

En ocasiones, el mensaje descifrado muestra el texto de dicho mensaje codificado en BASE64, en ese caso lo ideal es utilizar la utilidad “ripmime” para extraer los adjuntos MIME del mensaje descifrado:

```
# gpg --decrypt mensaje.eml > mensaje.mime
# mkdir dir_final
# ripmime mensaje.mime dir_final
```

Y esto nos crearía tantos ficheros como adjuntos tenga el mensaje en “directorio”.

Nota importante: la verificación de la firma del mensaje **indicará que la clave del remitente no es de confianza...** dejamos como **trabajo del estudiante** aprender a gestionar **la confianza de las claves con GnuPG** (list_keys, edit_key, trust -> 5, etc), cosa que se hizo anteriormente en Thunderbird, y **demostrar que la firma se ha hecho con una clave a la que hemos conferido la máxima confianza.**

Documentación y entrega de la práctica 5

Se ha de preparar un **DOCUMENTO DE TEXTO** (en PDF) **documentando exhaustivamente los pasos realizados en cada una de las partes de esta práctica**. El número de páginas no será inferior a 8, y se incluirán listados de todos los ficheros obtenidos en formato texto, hexadecimal, base64, PEM o similar, según cada caso. con ejemplos de los resultados obtenidos (parte binaria en hexadecimal, base64 o PEM) y **profusión de recortes de volcados de pantalla, tanto de las operaciones en Thunderbird como de consola**, en los que se ha PERSONALIZADO el “prompt” de la consola con el nombre y apellido del estudiante (por ejemplo, en mi caso, usaría el comando **export PS1=”Antonio Ocon> “**). Este “prompt” personalizado se ha de mostrar en **TODAS las restantes prácticas** que conlleven capturas de pantalla del sistema operativo.

Los estudiantes que **siguen la asignatura por curso** defenderán personalmente todas las prácticas **al profesor en el laboratorio**.

Los estudiantes que **no siguen la asignatura por curso** deberán subir el programa completo de **prácticas a la plataforma en convocatoria extraordinaria o especial**, en las fechas indicadas en la página de la asignatura.